

2.8 Outsourced Critical Activity Protection

Control Type: Mandatory	Applies to architecture:	A1	A2	A3	A4	B
		•	•	•	•	•
<u>Control Definition</u> Control Objective: Ensure the protection, in line with the CSCF, of the user's Swift infrastructure from risks exposed by the outsourcing of critical activities. In-scope components: - this organisational control is applicable when critical Swift-related activities are outsourced to a third party or, when relevant as per the notes, to a Swift connectivity provider. - as per the "Scope of Security Controls" section, the 'user's Swift infrastructure' encompasses the collection of, on-premises or remote (that is hosted or operated by a third party, or both), Swift-components managed by or for users by a third party, including applications, authentication services, network devices, all Alliance Connect VPNs, tokens and other removable media or equipment, and supporting hardware. Notes: - Use section "F) Outsourcing" of the "Scope of Security Controls" for proper scoping and expectations from the users engaging with third parties. - This control remains strongly recommended even when the outsourced activities are not critical. Risk Drivers: - exposure to sub-standard security practices						
<u>Implementation Guidance</u> Control Statement: Critical outsourced activities are protected, at a minimum, to the same standard of care as if operated within the originating organisation. Control Context: When critical activities are outsourced to third parties or Swift connectivity providers acting as an outsourcing agent, it is essential that at a minimum, the original standard of care for security is maintained (in addition to adherence to this customer security control framework) to make sure that no new weaknesses or vulnerabilities are introduced. The user's Swift infrastructure may face additional weaknesses or vulnerabilities due to its external exposure (to external resources or services) or its remote nature (when hosted in the cloud or with an external IT provider). Note: - Swift defines, at a minimum, the following activities related to the user's Swift infrastructure as critical: - security management and change management of the hardware, including HSM, and software (including applications, operating system, and underlying virtualised platform or infrastructure) - RMA and Business Transaction controls related operations (in support of controls 2.9 and 2.11) - accessing sensitive user data (for example, message content) - monitoring of events that contain sensitive user data - network management and configuration - Swift-related transaction operations (for example, creation or modification of a business transaction message within an interface or a connector) - security administration of the users entitlements, their tokens or (private) keys needed to perform Swift-related transaction operations - Ancillary services operations when sharing/reusing, for those ancillary services, credentials and roles/entitlements (accounts) used for Swift-related transaction operations. Otherwise, such separated/independent ancillary services accesses are not to be considered as in scope. - External contractors are not always considered as third party resources:						

- if those external contractors are members of the institution task force as contributors, then they are considered user's employees
- however, if external contractors manage or operate user's components remotely with their company equipment, as part of a managed service contractual agreement, they are considered as third-party resources.

Implementation Guidelines:

The implementation guidelines are common methods to apply the relevant control. The guidelines are a helpful way to begin an assessment but should never be considered as an audit checklist as each user's implementation may vary. Therefore, in cases where some implementation guidelines elements are not present or partially covered, mitigations as well as particular environment specificities must be considered to properly assess the overall compliance adherence level (as per the suggested guidelines or as per the alternatives).

- Service Level Agreements (SLAs) and a Non-disclosure Agreement (NDA) are established with any third party or Swift connectivity provider, when critical activities have been outsourced. These SLAs define the standard of care under which those critical operations are carried out by the third party or the Swift connectivity provider.
- A security risk assessment supporting the outsourcing to the third party is conducted at the start of the engagement, and is reviewed on a regular basis thereafter.
- Reasonable comfort provided by the third party confirms the outsourced activities are maintained in line with the [Outsourcing Agents Security Requirements Baseline](#).